Weekly Internship Report

NETWORK ENUMERATION & SERVICE VULNERABILITY DISCOVERY

WEEK : 2

Name:	Manahil Fayyaz
Roll No:	CSI-B1-200
Instructor:	Umar Niaz
Target :	Metasploitable 2

Cyberster

Executive Summary

This week's engagement focused on transitioning from broad passive reconnaissance to active network scanning and targeted service enumeration against the lab environment. Using Nmap as the primary tool, the assessment identified open ports, fingerprinted running services, detected known vulnerabilities via NSE scripting, and evaluated multiple evasion techniques against basic IDS and firewall controls.

Three critical-to-medium severity vulnerabilities were identified across FTP, SMTP, and HTTP services. Stealth and evasion testing confirmed that fragmented and decoy-based scanning techniques were the most effective at reducing noise detection.

Disclaimer: All activities documented in this report were conducted strictly for educational purposes within a controlled and isolated lab environment. No real-world systems, production infrastructure, or third-party networks were targeted or affected at any point during this assessment. The techniques and tools explored are intended solely to build foundational Red Team skills and develop a practical understanding of offensive security concepts.

Task 1:

Advanced Network Scanning with Nmap

Objective: To transition from broad reconnaissance to targeted network scanning, identifying open ports, and fingerprinting services while avoiding basic security triggers.

1. **TCP Connect Scan (-sT)** :
   It completes the full three-way handshake (SYN → SYN-ACK → ACK) with each target port. It is highly accurate and does not require root privileges, but it is the noisiest scan type as every connection is fully logged by the target OS and IDS.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sT -p 1-1000 -oN output_sT.txt 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-13 18:48 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
ns-servers
Nmap scan report for 192.168.14.3
Host is up (0.00075s latency).
Not shown: 988 closed tcp ports (conn-refused)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell

Nmap done: 1 IP address (1 host up) scanned in 0.22 seconds
```

2. **Stealth scan:**

   Stealth Scan (-sS) sends a SYN packet and waits for a response, but never completes the full handshake, it drops the connection after receiving SYN-ACK. This makes it significantly harder to detect and log, which is why it is the preferred scanning method.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -p 1-1000 -oN output_sS.txt 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-13 18:50 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
ns-servers
Nmap scan report for 192.168.14.3
Host is up (0.00019s latency).
Not shown: 988 closed tcp ports (reset)
PORT    STATE SERVICE
21/tcp  open  ftp
22/tcp  open  ssh
23/tcp  open  telnet
25/tcp  open  smtp
53/tcp  open  domain
80/tcp  open  http
111/tcp open  rpcbind
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
512/tcp open  exec
513/tcp open  login
514/tcp open  shell
MAC Address: 08:00:27:7E:3B:BE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.39 seconds
```

3. UDP Scanning (top 100 most common UDP ports):

UDP Scan (-sU) unlike TCP, UDP is a connectionless protocol with no handshake, making it slower and less reliable to scan. Nmap sends UDP packets to target ports and identifies open ports based on responses or lack thereof. It is commonly used to discover services like DNS (53), SNMP (161), and DHCP (67) that run exclusively over UDP.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sU --top-ports 100 -oN output_sU.txt 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-13 18:52 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try usi
ns-servers
Nmap scan report for 192.168.14.3
Host is up (0.0010s latency).
Not shown: 53 closed udp ports (port-unreach), 43 open|filtered udp ports (no-response)
PORT     STATE SERVICE
53/udp   open  domain
111/udp  open  rpcbind
137/udp  open  netbios-ns
2049/udp open  nfs
MAC Address: 08:00:27:7E:3B:BE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 51.88 seconds
```

4. Timing Templates:

sT_T2:

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -T2 -p 1-1000 -oN output_sS_T2.txt 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-13 18:55 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
ns-servers
Nmap scan report for 192.168.14.3
Host is up (0.00062s latency).
Not shown: 988 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
MAC Address: 08:00:27:7E:3B:BE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 402.08 seconds
```

sT_T3:

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -T3 -p 1-1000 -oN output_sS_T3.txt 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-13 19:02 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
ns-servers
Nmap scan report for 192.168.14.3
Host is up (0.00022s latency).
Not shown: 988 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
MAC Address: 08:00:27:7E:3B:BE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.30 seconds
```

sT_T4:

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -T4 -p 1-1000 -oN output_sS_T4.txt 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-13 19:03 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
ns-servers
Nmap scan report for 192.168.14.3
Host is up (0.00018s latency).
Not shown: 988 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
MAC Address: 08:00:27:7E:3B:BE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds
```

sT_T5:

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -T5 -p 1-1000 -oN output_sS_T5.txt 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-13 19:04 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
ns-servers
Nmap scan report for 192.168.14.3
Host is up (0.00020s latency).
Not shown: 988 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
MAC Address: 08:00:27:7E:3B:BE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.28 seconds
```

Comparison:

Scan	Command	Time Taken	Open ports
Slow	-T2	402.08 s	21,22,80,445…/ TCP
Normal	-T3	0.30 s	21,22,80,445…/ TCP
Fast	-T4	0.29 s	21,22,80,445…/ TCP
Extremely fast	-T5	0.28 s	21,22,80,445…/ TCP

This shows that in this specific lab environment, faster timing templates did **not** produce inconsistent or incomplete results, all four returned identical port findings. The trade-off is purely between **stealth and speed**. T2 is far less likely to trigger rate-based IDS detection due to its low packet rate, while T4 and T5 are nearly identical in speed but would be immediately flagged by any active network monitoring due to their high packet volume.

Task 2:

Service Fingerprinting & Banner Grabbing

After identifying open ports in Task 01, the next step is to determine what services are running on those ports and which versions they use. This process is called service fingerprinting. Knowing the exact version of a service helps security analysts identify known vulnerabilities associated with that software.

1. Service Version Detection with Nmap

Nmap can automatically detect the service name and version running on open ports.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-13 19:12 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
ns-servers
Nmap scan report for 192.168.14.3
Host is up (0.0082s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
```

```
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

2. Aggressive Scan

Nmap provides a more detailed scan using the Aggressive mode.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -A 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-13 19:18 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
s-servers
Nmap scan report for 192.168.14.3
Host is up (0.00077s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.14.4
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
```

3. Manual Banner Grabbing

It is the process of manually connecting to an open port on a target system to read the service banner , which often reveals the software name, version, and sometimes the OS.

Method 1 : Using Netcat

```
┌──(kali㉿kali)-[~]
└─$ nc 192.168.14.3 80
HEAD / HTTP/1.0

HTTP/1.1 200 OK
Date: Fri, 13 Mar 2026 19:45:46 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Connection: close
Content-Type: text/html
```

Method 2 : Using Telnet

```
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ telnet 192.168.14.3 80
Trying 192.168.14.3 ...
Connected to 192.168.14.3.
Escape character is '^]'.
HEAD / HTTP/1.0

HTTP/1.1 200 OK
Date: Fri, 13 Mar 2026 19:50:57 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Connection: close
Content-Type: text/html

Connection closed by foreign host.
```

4. SMB Enumeration (If Port 445 Is Open)

```
┌──(kali㉿kali)-[~]
└─$ enum4linux -a 192.168.14.3
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Fri Mar 13 20:04:16 2026

 ========================== ================ ( Target Information ) ================ ==========================
```

```
 ============================ ( Share Enumeration on 192.168.14.3 ) ============================


        Sharename       Type      Comment
        ---------       ----      -------
        print$          Disk      Printer Drivers
        tmp             Disk      oh noes!
        opt             Disk
        IPC$            IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
        ADMIN$          IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.

        Server               Comment
        ---------            -------

        Workgroup            Master
        ---------            -------
        WORKGROUP            METASPLOITABLE

[+] Attempting to map shares on 192.168.14.3

//192.168.14.3/print$   Mapping: DENIED Listing: N/A Writing: N/A
//192.168.14.3/tmp      Mapping: OK Listing: OK Writing: N/A
//192.168.14.3/opt      Mapping: DENIED Listing: N/A Writing: N/A

[E] Can't understand response:
```

```
user:[games] rid:[0×3f2]
user:[nobody] rid:[0×1f5]
user:[bind] rid:[0×4ba]
user:[proxy] rid:[0×402]
user:[syslog] rid:[0×4b4]
user:[user] rid:[0×bba]
user:[www-data] rid:[0×42a]
user:[root] rid:[0×3e8]
user:[news] rid:[0×3fa]
user:[postgres] rid:[0×4c0]
user:[bin] rid:[0×3ec]
user:[mail] rid:[0×3f8]
user:[distccd] rid:[0×4c6]
user:[proftpd] rid:[0×4ca]
user:[dhcp] rid:[0×4b2]
user:[daemon] rid:[0×3ea]
user:[sshd] rid:[0×4b8]
user:[man] rid:[0×3f4]
user:[lp] rid:[0×3f6]
user:[mysql] rid:[0×4c2]
user:[gnats] rid:[0×43a]
user:[libuuid] rid:[0×4b0]
user:[backup] rid:[0×42c]
user:[msfadmin] rid:[0×bb8]
user:[telnetd] rid:[0×4c8]
user:[sys] rid:[0×3ee]
```

Based on findings, **Port 445** was confirmed open during the Nmap scan, indicating an active SMB service on the target. This triggered the use of **Enum4linux** to dig deeper and extract information that a port scan alone cannot reveal , specifically shared folders, local user accounts, and group memberships.

Task 03:

Leveraging Nmap Scripting Engine (NSE)

Use automated scripts to detect vulnerabilities and misconfigurations during the scan.

Category	Purpose
discovery	Collects extra information about services
safe	Performs checks that are unlikely to disrupt services

Discovery :

```
┌──(kali㉿kali)-[~]
└─$ nmap --script discovery 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-13 20:21 UTC
Pre-scan script results:
| targets-asn:
|_  targets-asn.asn is a mandatory parameter
|_http-robtex-shared-ns: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtex.com/api/
|_hostmap-robtex: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtex.com/api/
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --d
ns-servers
Stats: 0:06:11 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.97% done; ETC: 20:27 (0:00:00 remaining)
Nmap scan report for 192.168.14.3
Host is up (0.00042s latency).
Not shown: 977 closed tcp ports (conn-refused)
Bug in http-security-headers: no string output.
PORT     STATE SERVICE
21/tcp   open  ftp
|_banner: 220 (vsFTPd 2.3.4)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.14.4
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
```

http-enum:

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 80 --script http-enum 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-14 18:22 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using -
s-servers
Nmap scan report for 192.168.14.3
Host is up (0.00047s latency).

PORT   STATE SERVICE
80/tcp open  http
| http-enum:
|   /tikiwiki/: Tikiwiki
|   /test/: Test page
|   /phpinfo.php: Possible information file
|   /phpMyAdmin/: phpMyAdmin
|   /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
|   /icons/: Potentially interesting folder w/ directory listing
|_  /index/: Potentially interesting folder

Nmap done: 1 IP address (1 host up) scanned in 1.68 seconds
```

Safe:

```
┌──(kali㉿kali)-[~]
└─$ nmap --script safe 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-14 18:24 UTC
Pre-scan script results:
|_http-robtex-shared-ns: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtex.com/api/
| targets-asn:
|_  targets-asn.asn is a mandatory parameter
|_hostmap-robtex: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtex.com/api/
|_broadcast-xdmcp-discover: ERROR
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dn
s-servers
Nmap scan report for 192.168.14.3
Host is up (0.00096s latency).
Not shown: 977 closed tcp ports (conn-refused)
Bug in http-security-headers: no string output.
PORT     STATE SERVICE
21/tcp   open  ftp
|_banner: 220 (vsFTPd 2.3.4)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.14.4
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
```

Part 2 : Running Vulnerability Scripts

```
┌──(kali㉿kali)-[~]
└─$ nmap --script vuln 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-14 18:41 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify v
s-servers
Nmap scan report for 192.168.14.3
Host is up (0.0034s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT     STATE SERVICE
21/tcp   open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPd version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs:  CVE:CVE-2011-2523  BID:48539
|       vsFTPd version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root)
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|       http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|       https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|_      https://www.securityfocus.com/bid/48539
22/tcp   open  ssh
23/tcp   open  telnet
```

This command runs all scripts in the vulnerability category against the target. It is usually helpful to combine vulnerability scanning with service version detection**.**

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sV --script vuln 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-14 18:59 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify v
s-servers
Nmap scan report for 192.168.14.3
Host is up (0.00063s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPd version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs:  CVE:CVE-2011-2523  BID:48539
|       vsFTPd version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root)
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|       http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|       https://www.securityfocus.com/bid/48539
|_      https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
```

Part 3 :Mapping NSE Output to CVE IDs

When Nmap's vulnerability scripts ran against the target, they automatically identified and mapped each detected service version to a known CVE ID. This process confirms that simply knowing a service version such as Vsftpd 2.3.4 or Apache HTTP Server below 2.2.15 is enough to pinpoint a specific, documented exploit with a measurable severity score (CVSS).

The three vulnerabilities flagged span from Critical (10.0) down to Low (3.4), demonstrating that a single scan can surface risks of varying impact across different services simultaneously. This is the core value of NSE scripting ; it bridges the gap between raw port discovery and actionable vulnerability intelligence in a single automated step.

Port	Service	Version	CVE ID	CVSS	Description
21	FTP	Vsftpd 2.3.4	CVE-2011-2523	10.0 (Critical)	vsftpd backdoor opens shell on port 6200/tcp
25	SMTP	SSL 3.0	CVE-2014-3566	3.4 (low)	POODLE — SSL information leak via downgrade attack
8180	HTTP	Apache http server < 2.2.15	CVE-2007-6750	5.0 (Medium)	Slowloris : Denial of Service via partial HTTP requests

Task 04:

Stealth & Firewall Evasion Techniques

Objective: Practice techniques to bypass basic Intrusion Detection Systems (IDS) or Firewalls.

Technique 1 : Packet Fragmentation (-f)

- Splits the scan packets into smaller fragments.
- Helps demonstrate how packet inspection systems handle fragmented traffic.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -f 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-14 20:21 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
s-servers
Nmap scan report for 192.168.14.3
Host is up (0.00025s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
```

```
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 08:00:27:7E:3B:BE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.33 seconds

┌──(kali㉿kali)-[~]
└─$
```

Scan Type	Command	Result
Normal	nmap -sS <target>	21,22,23,25,53,80,111,139,445,512,513,514
Fragmented	nmap -sS -f <target>	21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306….

Technique 2 : MTU Manipulation

- MTU (Maximum Transmission Unit) controls the size of packets sent over a network.

- Changing MTU alters how packets are divided during transmission.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS --mtu 16 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-15 10:15 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
s-servers
Nmap scan report for 192.168.14.3
Host is up (0.00035s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
```

Comparison:

Scan Type	Command	Scan Time	Ports
Normal	-sS	0.39 s	21,22,23,25,53,80,111,139,445,512,513,514
Fragmented	-f	0.33 s	21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306,5432,5900,6000,6667,8009,8180
MTU	--mtu	0.52 s	21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306,5432,5900,6000,6667,8009,8180

Part 2: Decoys and Source Port Manipulation

Technique 1 :Decoy Scanning (-D)

- Decoy scanning makes it appear as though multiple systems are performing the scan.
- Instead of one IP sending packets, Nmap inserts decoy IP addresses along with the real scanner.
- The target system may see scan packets appearing to come from 10 different addresses.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -D RND:10 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-15 10:26 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
s-servers
Nmap scan report for 192.168.14.3
Host is up (0.00031s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
```

Technique 2 : Source Port Manipulation

- Nmap allows the scan to appear as if it originates from a specific port.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS --source-port 53 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-15 10:31 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
s-servers
Nmap scan report for 192.168.14.3
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
```

Scan Type	Command	Scan Time	Ports
Normal	-sS	0.39 s	21,22,23,25,53,80,111,139,445,512,513,514
Decoy	-D	0.33 s	21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306,5432,5900,6000,6667,8009,8180
Source Port	--source-port	0.26 s	21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306,5432,5900,6000,6667,8009,8180

Potential Vulnerabilities Discovered

The following vulnerabilities were identified through Nmap service fingerprinting, banner grabbing, and NSE vulnerability scripts. Each maps to a known CVE with a confirmed CVSS severity rating.

CVE-2011-2523 ; Vsftpd 2.3.4 Backdoor (Port 21 / FTP) A critical-rated backdoor (CVSS 10.0) embedded in the Vsftpd 2.3.4 source code. Sending a username containing ":)" triggers a root shell on port 6200/TCP — giving full remote access with no credentials required.

CVE-2014-3566 ;SSL POODLE Information Leak (Port 25 / SMTP) A low-rated protocol flaw (CVSS 3.4) in SSL 3.0. An attacker in a man-in-the-middle position can force a TLS downgrade and decrypt sensitive traffic. No patch exists — SSL 3.0 must be disabled entirely.

CVE-2007-6750 ; Slowloris DoS Attack (Port 8180 / HTTP) A medium-rated vulnerability (CVSS 5.0) affecting Apache versions below 2.2.15. Slowloris floods the server with incomplete HTTP requests, exhausting connections and causing a denial of service. Remediation requires updating Apache and enabling the mod_reqtimeout module.

Evasion Results

Multiple stealth and evasion techniques were tested to evaluate how each scan type interacts with network monitoring and firewall controls. The table below summarizes observed noise levels and effectiveness.

Technique	Flag Used	Noise Level	Assessment
SYN Stealth Scan	-sS	**Low**	Preferred for Red Teaming , no full TCP handshake, harder to log
TCP Connect Scan	-sT	**High**	Completes full handshake ,easily logged by IDS/firewalls
Slow Timing	-T2	**Very Low**	402s scan time; highly effective at evading rate-based detection
Normal/Fast Timing	-T3/-T4/-T5	**Medium–High**	Fast (~0.28–0.30s) but easily flagged by anomaly detection
Packet Fragmentation	-f	**Low–Medium**	Bypassed basic inspection; revealed more open ports than normal scan
MTU Manipulation	--mtu	**Low–Medium**	Similar to fragmentation; slightly slower but effective at packet-level evasion

Technique	Flag Used	Noise Level	Assessment
Decoy Scanning	-D	**Low**	Masks true scanner IP among 10 decoys , effective IP attribution evasion
Source Port Spoof	--source-port	**Low**	Bypasses port-based firewall rules

Actionable Insights : Most Likely Initial Access Point

Recommended Initial Access Vector: Port 21 / FTP

Port 21 running Vsftpd 2.3.4 is the most viable initial access point identified during this assessment. This conclusion is based on the following factors:

- Maximum Severity: CVSS score of 10.0 (Critical) ,the highest possible rating. No other finding comes close in terms of exploitability and impact.
- No Authentication Required: The backdoor can be triggered by any unauthenticated user with network access to port 21. There is no need for credential harvesting, brute force, or privilege escalation.
- Remote Code Execution: Exploitation grants a root-level command shell on port 6200/TCP , providing complete control over the target system immediately upon exploitation.
- Widely Exploitable: This backdoor is publicly documented, has a Metasploit module (exploit/unix/ftp/vsftpd_234_backdoor), and requires minimal attacker skill to exploit.
- No Patch Available: The vulnerability cannot be patched , the affected binary must be replaced entirely with a clean, trusted version. Any system still running this version is fully exposed.